DOON BUILDERS

SINCE 1968

WEBSITE PROJECT REPORT

Complete project report & security audit

What the Doon Builders website is built with, how it is organised, every colour, font and design token it uses, and the result of an 11-step security and release check.

PROJECT	TYPE	REPORT DATE	RELEASE STATUS
doon-builders v1.0.0	Static React website	9 October 2026	Not ready to deploy

01 Summary

The website is a well-built static React site with no server and no database. The code is clean and safe: no secrets, no unsafe HTML, and no vulnerable libraries reach the browser. It is not ready to go live, because the code has no backup, the domain has no HTTPS and no security headers are set.

73 source files in `src/`	**7,131** lines of code	**10** pages (routes)	**181 KB** JavaScript sent to visitors (gzip)
0 vulnerabilities in code that runs in the browser	**0** secrets or keys found	**0** git commits — no backup yet	**16** projects (4 real, 12 samples)

Security and release pipeline — results

1	**Code review** No unsafe patterns. Minor notes only.	PASS
2	**Dependency scan** Browser code: 0 issues. Build tools: 7 issues, all via Tailwind CSS 3.	PASS, WITH NOTES
3	**Secrets scan** No keys, tokens or passwords in source, build or zip.	PASS
4	**Authentication testing** No login, accounts or admin panel exist.	NOT APPLICABLE
5	**Authorization testing** Everything is public by design. Check that the published documents are meant to be public.	NOT APPLICABLE
6	**XSS / SQL injection testing** React escapes all output; URL inputs use allowlists. No database exists.	PASS
7	**API testing** The only API is the contact form, and no provider is configured yet.	PARTLY TESTED
8	**Rate-limit testing** The form has no rate limit or captcha, only a honeypot.	ACTION NEEDED
9	**HTTPS / security headers** doonbuilders.com has no HTTPS. No security headers are configured.	ACTION NEEDED
10	**Backup / restore test** Clean rebuild works, but the git repository has 0 commits and no remote.	ACTION NEEDED
11	**Deploy** The build works. Blocked by steps 8–10 and placeholder content.	NOT READY

Method: the source code, configuration and build output were inspected; `npm audit`, `npm outdated` and a production build were run; the build was restored from a clean copy; and the live domain's HTTP/HTTPS response was checked on 9 Oct 2026. Nothing was deployed or changed.

02 Technology — what the site is built with

The site is a single-page application. The browser downloads one HTML file, and React builds every page from JavaScript. There is no backend server, no database and no login.

Languages

LANGUAGE	WHERE IT IS USED
JavaScript (ES modules) + JSX	All pages, components, data and logic (`.js` / `.jsx` files). No TypeScript.
CSS via Tailwind CSS	Utility classes in components, plus `src/styles/globals.css` for colours, type and shared classes.
HTML	One file, `index.html` : SEO meta tags, fonts, theme script, Organization schema.
SVG	Favicon, the animated blueprint intro, icons (Lucide).

Libraries used in the browser (production dependencies)

PACKAGE	VERSION	PURPOSE
react	19.3.0	UI library; builds every page from components.
react-dom	19.3.0	Renders React into the page.
react-router-dom	7.18.4	Page routing (`/about` , `/projects/:slug` …) without reloading the page.
gsap (+ ScrollTrigger)	3.15.0	All animations: intro drawing, scroll reveals, pinned "Three Generations" section, parallax.
@gsap/react	2.1.2	`useGSAP` hook; cleans up animations safely in React.
lenis	1.3.26	Smooth scrolling, kept in sync with GSAP.
lucide-react	1.49.0	Line icons (arrows, phone, mail, chevrons …).

Build tools (development only — not sent to visitors)

PACKAGE	VERSION	PURPOSE
vite	8.3.1	Dev server (port 5173) and production bundler (Rolldown). Splits code into `react` , `motion` and app chunks.
@vitejs/plugin-react	6.1.1	JSX compilation and fast refresh.
tailwindcss	3.4.19	Generates CSS from utility classes. Dark mode via `[data-theme="dark"]` .
postcss + **autoprefixer**	8.5.28 / 10.6.1	CSS processing and browser prefixes.

External services

SERVICE	USE
Google Fonts	Poppins and Noto Serif Devanagari, loaded from `fonts.googleapis.com`.
WhatsApp (wa.me)	Click-to-chat links with a pre-filled message.
Contact form provider	One of Web3Forms, FormSubmit, Netlify Forms or a custom API, chosen with `VITE_CONTACT_PROVIDER`. **None is configured yet.**
Hosting	Ready-made configs for Netlify (`netlify.toml` , `public/_redirects`) and Vercel (`vercel.json`).

Environment: Node.js 24.21.0 and npm 11.19.0 on this machine (README requires Node 18+).

03 Project structure

A page is built in layers, from the HTML shell down to the data files. All visible content lives in `src/data/`, so text, projects and photos change without touching components.

```
DOON/
├─ index.html                 single HTML page — SEO tags, fonts, theme script, schema
├─ package.json               dependencies and scripts (dev / build / preview)
├─ vite.config.js             bundler: @ alias, port 5173, vendor chunks
├─ tailwind.config.js         colours, fonts, shadows, easing, widths
├─ postcss.config.js          Tailwind + Autoprefixer
├─ netlify.toml · vercel.json hosting: build command, rewrites, cache headers
├─ .env.example               contact-form and site-URL settings (empty)
├─ public/                    served as-is: images (228 files, 26 MB), video (3.5 MB),
│                             favicons, og image, robots.txt, sitemap.xml, manifest
├─ documents/                 original-records PDF and its HTML source (not in the build)
└─ src/
   ├─ main.jsx                starts React + router
   ├─ App.jsx                 the list of routes
   ├─ layout/     (1)         MainLayout — intro, navbar, footer, floating call buttons
   ├─ pages/      (10)        one file per URL
   ├─ sections/home/ (13)     the Home page blocks, in story order
   ├─ components/ (29)        shared pieces: buttons, cards, media, lightbox, navbar …
   ├─ data/       (11)        ALL content: company, projects, archive, machinery, SEO …
   ├─ hooks/      (2)         useLenis (smooth scroll), useGSAPAnimation (reveals)
   ├─ lib/        (3)         gsap set-up, theme (light/dark), intro state
   ├─ services/   (1)         contactService — form sending + validation
   └─ styles/     (1)         globals.css — colour tokens, type, shared classes
```

Pages and URLs

URL	FILE
`/`	Home.jsx
`/projects` (?filter=)	Projects.jsx
`/projects/:slug`	ProjectDetail.jsx

Home page blocks (in order)

#	SECTION
1	Hero (background video)
2	Legacy
3	Stats (58+ yrs, 180+ projects, 3 generations)

`/ongoing-projects`	OngoingProjects.jsx
`/projects-delivered`	DeliveredProjects.jsx
`/experience`	Experience.jsx
`/machineries` (?category=)	Machinery.jsx
`/about`	About.jsx
`/contact`	Contact.jsx
anything else	NotFound.jsx

4	Capabilities
5	Showcase
6	Site Gallery
7	Featured Projects
8	Government Projects
9	Private Projects
10	Machinery Preview
11	Three Generations (pinned)
12	Why Doon
13	Final CTA

Shared components (29)

GROUP	COMPONENTS
Frame & navigation	Navbar, MobileMenu, Footer, Blessing (Hindi strip), Logo, ThemeToggle, ScrollToTop, FloatingActions (call / WhatsApp)
Page building	PageHero, SectionHeader, CTABand, Button, FilterBar, MaskLines, ImageReveal
Content cards	ProjectCard, MachineryCard, ArchiveCard, StatCounter, StageIndicator, Timeline, PlaceholderBadge
Media	Media (AVIF/WebP responsive images), Lightbox, DigitalCopy (typed copy of records), Intro (blueprint animation), WhatsAppIcon
Forms & SEO	ContactForm, Seo (title, description, Open Graph, canonical)

Content files (`src/data/`)

FILE	WHAT IT HOLDS	CURRENT STATE
company.js	Name, phone 89230 76963, email, WhatsApp, stats, socials, address, logo	Address, map, logo, legal name, socials empty
projects.js	All projects and filters	4 real + 12 sample entries
archive.js	Original records: 1976, 1980, 1990 work orders; 2023 Dubai licence; current site record	5 records with scans
machinery.js	Machinery list and Home fleet groups	7 sample entries (stock photos)
timeline.js	Three generations: 1968, 1998, 2020	2nd/3rd generation names empty
capabilities.js	What we build, why us, form project types	Complete
images.js	Which image file is used where; portraits	Portraits not supplied

showcase.js, siteGallery.js	Home showcase slides and site photos	6 real site photos
navigation.js, seo.js	Menu/footer links; page titles and descriptions	Complete

Media assets

FOLDER	CONTENTS
images/site/	Real Doon Builders site photos (6 subjects, 480/960 px)
images/archive/	Scans of original records (5 records, multiple close-ups)
images/placeholder/, stock/	**Temporary** stock photos (Unsplash, Wikimedia CC0 / CC BY-SA). Credits in `stock/CREDITS.md`. Must be replaced before launch.
videos/	Hero video at 480p and 720p, plus a poster image. Mixkit stock footage of a Los Angeles site.
Formats	Each photo comes as AVIF and WebP at 2–3 widths (640/1280/1920). The `<Media>` component picks the best size and lazy-loads.

04 Colours

Colours are defined in two places: fixed brand colours in `tailwind.config.js`, and theme colours as CSS variables in `src/styles/globals.css`. The theme variables change in dark mode.

Brand colours (same in light and dark mode)

Brand Red
`#C8102E`
Primary buttons, logo, links, focus ring, text selection, favicon bar, app theme colour

Brand Deep
`#A50E27`
Button hover / pressed state

Brand Bright
`#E8475B`
Small red text on dark backgrounds (contrast)

Gold
`#F7D774`
Hindi blessing text and Om marks on the red strip

Charcoal
`#181A1D`
Dark cards, image overlays, dark-mode browser bar

Night
`#111214`
Darkest sections, favicon background

White
`#FFFFFF`
Text on red and dark, light-mode browser bar, manifest background

Line (dark)
`rgba(255,255,255,.15)`
Dividers on fixed-dark sections

Light theme

Ink
`#111214 · 17 18 20`
Main text

Paper
`#F6F7F9 · 246 247 249`
Page background, inputs

Surface
`#FFFFFF · 255 255 255`
Cards, focused inputs

Mist
`#E6E8EC · 230 232 236`
Image backgrounds, placeholders

Steel
`#777B80 · 119 123 128`
Muted text, placeholder text, intro lines

Steel Dark
`#55595E · 85 89 94`
Secondary text, labels, lead paragraphs

Line
`rgba(20,20,20,.12)`
Borders and dividers

Scrollbar
`#B9BAB7`
Scrollbar thumb (desktop)

Dark theme

Ink
`#ECEDF0 · 236 237 240`
Main text

Paper
`#0D0E10 · 13 14 16`
Page background

Surface
`#181A1D · 24 26 29`
Cards

Mist
`#2C2F34 · 44 47 52`
Image backgrounds

Steel
`#9499A0 · 148 153 160`
Muted text

Steel Dark
`#B2B7BE · 178 183 190`
Secondary text

Brand Text
`#F05468 · 240 84 104`
Red text, brightened for dark backgrounds

Scrollbar
`#3A3D42`
Scrollbar thumb; line is rgba(255,255,255,.11)

Third-party colours

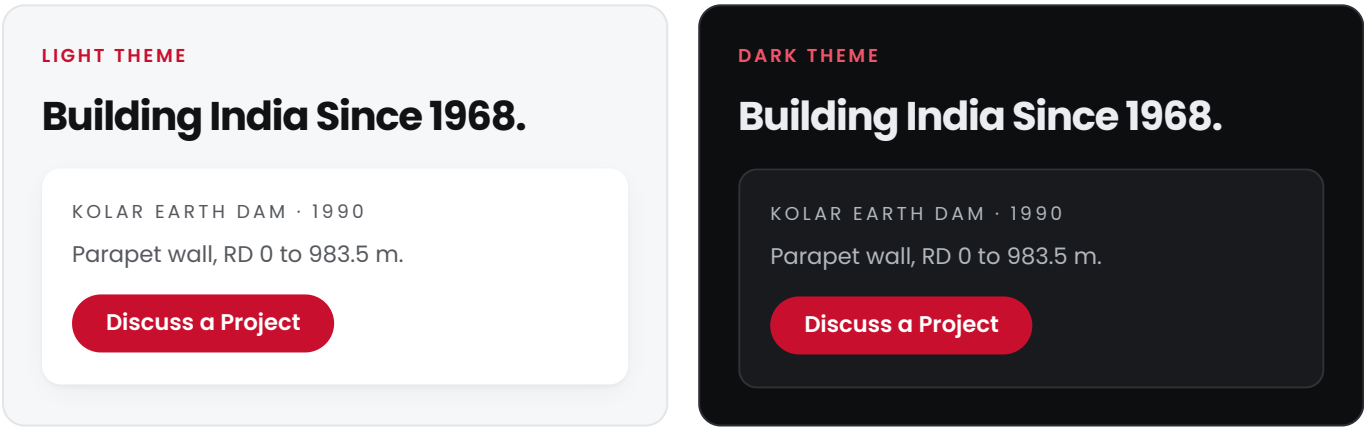
WhatsApp Green
`#25D366`
WhatsApp buttons (CTA, floating, mobile menu)

WhatsApp Hover
`#1FBE5B`
CTA button hover

WhatsApp Icon
`#1DA851`
Icon colour in navbar and footer

Brand Tints
`red at 5–15% opacity`
Eyebrow pills, input focus glow, alert boxes, hero glow

The two themes side by side



The theme follows the device setting. A visitor can switch it with the navbar toggle, and the choice is saved in `localStorage` under the key `db-theme`. A small script in `index.html` applies the theme before the page first paints, so the page never flashes the wrong theme.

Shadows

TOKEN	VALUE	USED FOR
shadow-card	`0 1px 2px rgba(17,18,20,.04), 0 4px 16px -4px rgba(17,18,20,.08)`	Resting cards
shadow-card-hover	`0 2px 4px rgba(17,18,20,.04), 0 24px 48px -12px rgba(17,18,20,.22)`	Hovered cards, WhatsApp CTA
shadow-card-press	`0 4px 8px rgba(17,18,20,.06), 0 32px 64px -16px rgba(17,18,20,.30)`	Pressed cards
shadow-nav	`0 1px 0 rgba(17,18,20,.06), 0 8px 24px -12px rgba(17,18,20,.14)`	Navbar after scrolling
shadow-brand	`0 10px 24px -10px rgba(200,16,46,.55)`	Red buttons (red glow)

05 Typography, layout and motion

Fonts

FONT	WEIGHTS	USE
Poppins	400 · 500 · 600 · 700 · 800	Everything in English. Fallbacks: system-ui, Segoe UI, Roboto, Arial.
Noto Serif Devanagari	600 · 700	The Hindi blessing line: "ॐ भगवान श्री टपकेश्वर महादेव जी की कृपा से". Fallbacks: Nirmala UI, Mangal.

Type scale

.display-xl — hero headings
clamp(2rem, 4.8vw, 4rem) · 700 · lh 1.04 · -0.035em

Since 1968

.h-section — section headings
clamp(1.75rem, 3.6vw, 3rem) · 700 · lh 1.08

Three Generations

.h-card — card headings
clamp(1.4rem, 2.4vw, 2rem) · 700

Kolar Earth Dam

.lead — intro paragraphs
16–18px · lh 1.75 · steel-dark

Projects built to last.

body
15px mobile, 16px from 768px · lh relaxed

Regular paragraph text.

.eyebrow / **.meta-label**
11px · uppercase · tracking .14em / .18em

OUR LEGACY

Layout tokens

TOKEN	VALUE
Max content width	1440px (`.container-x`); text column 38rem
Page gutter (`--gutter`)	20px mobile · 32px from 768px · 48px from 1024px · 80px from 1440px
Navbar height (`--nav-h`)	68px · 76px from 1024px · 60px on short screens
Blessing strip (`--blessing-h`)	44px · 48px · 52px · 36px on short screens
Section spacing	48px · 64px · 80px vertical padding (`.section-y`)
Breakpoints	Tailwind defaults: sm 640 · md 768 · lg 1024 · xl 1280 · 2xl 1536
Corner radius	Cards 16px (`rounded-2xl`), inputs 12px, buttons and pills fully round
Easing (`ease-arch`)	`cubic-bezier(0.22, 1, 0.36, 1)` : fast start, soft settle

Backgrounds	`.bg-blueprint` (44px grid + red glow), `.grid-lines`, `.placeholder-grid` (32px grid)

Motion and accessibility

FEATURE	BEHAVIOUR
Intro	A blueprint drawing of a building, then the wordmark (about 3.9s). Plays once per browser session. A click or key press skips it.
Scroll reveals	`data-reveal` = lines · fade · stagger · image · rule, plus `data-parallax`, all run by GSAP ScrollTrigger.
Smooth scroll	Lenis, duration 1.15s, driven by the GSAP ticker.
Cards	Lift 6px and scale 1.2% on hover; the image zooms 6% over 1.2s.
Page change	0.6s fade-up (`.page-enter`).
Reduced motion	No intro, no smooth scroll, no reveals, no video autoplay. The pinned section becomes a normal stack.
Accessibility	Skip link, semantic landmarks, visible focus ring (2px brand red), labelled fields with inline errors, Escape closes menus and lightboxes and returns focus.

06 SEO, build and hosting

SEO and sharing

ITEM	STATUS
Per-page title + description	Yes. `src/data/seo.js` sets them through the `<Seo>` component.
Open Graph / Twitter cards	Yes, with a 1200×630 image at `/og/og-default.jpg`.
Canonical URL, og:url	**Off.** They only appear once `VITE_SITE_URL` is set.
Organization schema (JSON-LD)	Name, founding year, phone and email.
robots.txt, sitemap.xml	Present, with 11 URLs on `https://doonbuilders.com`.
Web app manifest	Present, theme colour `#c8102e`, icons 32 / 180 / 512 px.
No-JavaScript fallback	A `<noscript>` line with the phone and email.

Production build (`npm run build`, 1.4s)

FILE	SIZE	GZIP	CONTENTS
react-*.js	258.6 KB	82.1 KB	React, React DOM, router
index-*.js	182.1 KB	49.0 KB	Site code and data
motion-*.js	132.3 KB	49.7 KB	GSAP, ScrollTrigger, Lenis
index-*.css	67.0 KB	12.8 KB	All styles
Total code	**640.6 KB**	**193.9 KB**	Plus about 30 MB of images and video, loaded on demand

Hosting configuration

FILE	WHAT IT DOES
netlify.toml	Builds with `npm run build` and publishes `dist`. Caches `/assets/*` for 1 year and `/images/*` for 7 days.
public/_redirects	`/* /index.html 200`, so deep links like `/about` work on Netlify.
vercel.json	The same rewrite, and a 1-year cache on `/assets/*`. It has no `/images` cache rule.
vite.config.js	The dev server allows `*.trycloudflare.com` tunnels for sharing previews.

Environment variables (`.env`)

VARIABLE	PURPOSE	SET?
VITE_SITE_URL	Canonical and sharing URLs	No
VITE_CONTACT_PROVIDER	web3forms · formsubmit · netlify · custom	No
VITE_CONTACT_FORM_KEY	Web3Forms public access key	No
VITE_CONTACT_ENDPOINT	FormSubmit or custom API URL	No

> **Note on VITE_ variables**
>
> Every `VITE_` value is copied into the public JavaScript file, so anyone can read it. Only public keys (such as a Web3Forms access key) may go here, never passwords or private API keys.

07 Security and release audit — step by step

1 Code review

PASS

- No `dangerouslySetInnerHTML`, `innerHTML`, `eval`, `new Function` or `document.write` anywhere in `src/`.
- All 9 links that open in a new tab use `rel="noopener noreferrer"`.
- URL inputs are checked against allowlists: `?filter=` and `?category=` fall back to "all", and an unknown `/projects/:slug` shows the 404 page.
- Browser storage holds only the theme choice (`db-theme`) and an intro-seen flag. No personal data is stored.
- The contact form never claims to have sent a message unless the provider confirms it.

Minor notes: only the message field has a length limit (4,000 characters); the provider should limit the other fields. Sending is not idempotent, so if a request times out, a retry can send a duplicate enquiry.

2 Dependency scan

PASS, WITH NOTES

- `npm audit --omit=dev`: **0 vulnerabilities** in libraries that ship to the browser.
- `npm audit` (all): **7 vulnerabilities (5 high, 2 moderate)**, all inside Tailwind CSS 3.4.19's build-time chain: braces, micromatch, fast-glob, chokidar, postcss-nested, postcss-selector-parser. They are denial-of-service bugs that need malicious input files at build time. Visitors are not affected.
- Patch updates available: vite 8.3.1 → 8.3.4, @vitejs/plugin-react 6.1.1 → 6.1.2, lucide-react 1.49 → 1.54, postcss 8.5.28 → 8.5.29.

Fix: run `npm update` now. Plan a migration to Tailwind CSS 4 (a breaking change) to clear the build-tool advisories. Do not run `npm audit fix --force` blindly, because it will break the styling.

3 Secrets scan

PASS

- Source, config, `dist/` and `doonbuilders-site.zip` were searched for API keys, tokens, passwords, private keys and AWS / GitHub / Google / OpenAI key patterns. **None found.**
- No `.env` file exists. `.gitignore` already excludes `.env`, `.env.local` and `.env.*.local`. `.env.example` holds only empty values.

Fix: add `*.zip` to `.gitignore`, so the 25 MB build zip is not committed by mistake.

4 Authentication testing

NOT APPLICABLE

The site has no login, user accounts, admin panel, sessions or cookies of its own, so there is nothing to test. If a CMS or admin area is added later, test this step again before launch.

5 Authorization testing

NOT APPLICABLE

There are no protected pages or private data. Everything in `src/data/` and `public/` ships to every visitor's browser, so treat all of it as public.

Review: the 2023 Dubai professional licence (licence no. 1174457) is published as full-page scans. The typed copy leaves out the owner's name, but the full-page scan may still show it in Arabic. The licence expired on 9 April 2024. Confirm that the owner agrees to publishing it.

6 XSS / SQL injection testing

PASS

- **SQL injection:** not possible. The site has no database and no server code.
- **XSS:** React escapes everything it renders, and the code uses no raw-HTML functions. The SEO tags are set with `setAttribute`, which is safe. The JSON-LD schema is fixed text.
- Values from the URL (filter, category, slug) only ever choose from fixed lists and are never printed back as HTML.
- Link targets (phone, email, WhatsApp, socials, map) come from `company.js`, which only developers edit.

Keep in mind: when social or map links are added, use only `https://` URLs.

7 API testing

PARTLY TESTED

- The only outgoing API call is the contact form (`src/services/contactService.js`).
- Tested by reading the code: with no provider set, the form shows "Online enquiries are not connected yet" and gives the phone and email. A network or provider failure shows an error message with the phone number. The honeypot field silently drops bots.
- The live request could not be tested, because no provider is configured.

Once a provider is set, test: a valid submission (does the email arrive?), an invalid key or endpoint (the error message should appear), offline mode, and a filled honeypot (nothing should be sent). Netlify Forms only works when the site is hosted on Netlify.

8 Rate-limit testing

ACTION NEEDED

- The site has no server, so it cannot rate-limit anything itself. The form's only protections are a honeypot field and a disabled button while a message is sending.
- A bot that skips the honeypot can flood the company inbox, and Web3Forms / FormSubmit free plans have monthly limits that spam can use up.

Fix before switching the form on: enable the provider's captcha and spam filter. Options: Web3Forms with hCaptcha, Netlify Forms with reCAPTCHA (Akismet filtering is on by default), or Cloudflare Turnstile with a custom endpoint. A custom API must enforce its own per-IP limit, for example 5 requests per 10 minutes.

9 HTTPS / security-header check

ACTION NEEDED

- **Live check (9 Oct 2026):** `https://doonbuilders.com` failed the TLS handshake, so the domain has no working HTTPS. `http://doonbuilders.com` returned **404 Not Found** from a "DPS/2.0.0" server. The website is not deployed on this domain yet.
- **Config check:** `netlify.toml` and `vercel.json` set only `Cache-Control`. None of these headers is set: Content-Security-Policy, Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options / frame-ancestors, Referrer-Policy, Permissions-Policy.

Fix: point the domain's DNS at Netlify or Vercel (both provide free automatic HTTPS) and add the headers shown in the appendix.

10 Backup / restore test

ACTION NEEDED

- **Restore test passed:** only the source files were copied to an empty folder, then `npm ci` and `npm run build` were run. The build succeeded and produced **identical file hashes**, so the build is reproducible from source.
- **No backup exists:** the git repository has **0 commits** and no remote. Every file is untracked, so one disk failure or accidental delete would lose the whole project.
- `doonbuilders-site.zip` holds only the built site (203 files), not the source code, so it is not a backup. Its paths use Windows `\` separators, which can break when unzipped on Linux hosts.

Fix now: make the first commit and push it to a private GitHub repository. Keep a dated copy of `public/images/archive/` and `documents/` (the original scans) somewhere separate, such as Google Drive.

11 Deploy

NOT READY

The build works and both hosting configs are correct. Nothing was deployed during this audit. The following must be done before going live:

- Steps 8, 9 and 10 above.
- Replace the 12 sample projects and 7 sample machinery entries. Replace the stock photos and the Los Angeles hero video with real Doon Builders media.
- Set `VITE_SITE_URL` and configure the contact provider.
- Add the logo, registered name, office address, map link, social links, generation names and portraits.

08 Action list, in priority order

#	ACTION	PRIORITY	EFFORT
1	First git commit and push to a private GitHub repo; add `*.zip` to `.gitignore`	CRITICAL	10 min
2	Connect the domain to Netlify/Vercel with HTTPS	HIGH	30 min
3	Add security headers (appendix) and test them at securityheaders.com	HIGH	30 min
4	Configure the contact provider with captcha, then run the API tests from step 7	HIGH	1 hour
5	Replace sample projects, machinery, stock photos and the hero video	HIGH	Content
6	Set `VITE_SITE_URL` ; fill in logo, address, map and socials in `company.js`	MEDIUM	15 min
7	Confirm consent for publishing the Dubai licence scans	MEDIUM	—
8	`npm update` for patch versions	MEDIUM	5 min
9	Plan the Tailwind CSS 4 migration to clear build-tool advisories	LOW	Half a day
10	Add an `/images/*` cache rule to `vercel.json` (if using Vercel)	LOW	5 min

Appendix A — recommended security headers for `netlify.toml`

```
# Add below the existing [[headers]] blocks.
# The sha256 hash allows the inline theme script in index.html.
# If that script is edited, recompute the hash, or the theme will not load before first paint.
[[headers]]
  for = "/*"
  [headers.values]
    Strict-Transport-Security = "max-age=31536000; includeSubDomains"
    X-Content-Type-Options = "nosniff"
    X-Frame-Options = "DENY"
    Referrer-Policy = "strict-origin-when-cross-origin"
    Permissions-Policy = "camera=(), microphone=(), geolocation=(), payment=()"
    Content-Security-Policy = "default-src 'self'; script-src 'self' 'sha256-qWMmeLj9qnOJuXE87IHmK84/PcONhXQt+
KDpeKgtj7k='; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gst
atic.com; img-src 'self' data:; media-src 'self'; connect-src 'self' https://api.web3forms.com https://formsub
mit.co; frame-ancestors 'none'; base-uri 'self'; form-action 'self'; object-src 'none'; upgrade-insecure-reque
sts"
```

For Vercel, add the same six headers to `vercel.json` under `"headers"` with `"source": "/(.*)"`. If a custom API endpoint is used, add its domain to `connect-src`. Load the site after deploying and check the browser console for CSP errors.

Appendix B — commands used in this audit

```
npm audit                 # all dependencies → 7 (dev-only)
npm audit --omit=dev      # browser dependencies → 0
npm outdated              # 4 patch updates available
npm run build             # production build → passes in 1.4s
npm ci && npm run build   # restore test from a clean copy → identical output
curl -I https://doonbuilders.com   # TLS handshake failed
curl -I http://doonbuilders.com    # 404, server DPS/2.0.0
```

Report generated 9 October 2026 from the working copy at `C:\Zyvox EXE\DOON`. Source for this PDF: `documents/source/project-report.html`.